

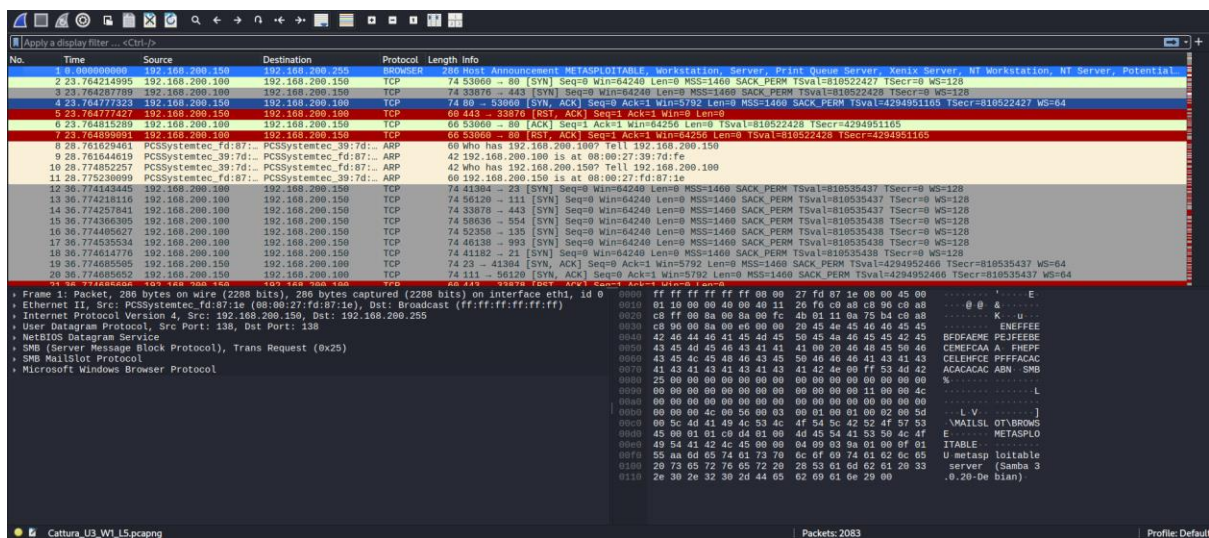
Report Incident Response – Analisi Wireshark

Introduzione:

Viene richiesto di analizzare la cattura con Wireshark attentamente e rispondere ai seguenti quesiti:

1. Identificare ed analizzare eventuali IOC, ovvero evidenze di attacchi in corso
2. In base agli IOC trovati, fare delle ipotesi sui potenziali vettori di attacco utilizzati.
3. Consigliare un'azione per ridurre gli impatti dell'attacco attuale ed eventualmente un simile attacco futuro

1. Inizio Analisi



Da una prima analisi, vengono identificati due IP;

Attaccante: 192.168.200.100

Vittima: 192.168.200.150

L'attaccante ha effettuato prima un nmap discover o un netdiscover perché evidentemente non conosceva la superficie d'attacco.

Lo screenshot evidenzia due comportamenti critici che costituiscono IOC di tipo Network Based (?)

Osservando i pacchetti da 2 a 12; 192.168.200.100 invia una raffica rapida di pacchetti TCP con flag [SYN], La destinazione cambia porta ad ogni pacchetto in una frazione di secondo:

- Porta 23 (Telnet)
- Porta 111 (RPC)
- Porta 443 (HTTPS)
- Porta 554 (RTSP)
- Porta 135 (MSRPC)
- Porta 21 (FTP)

Questa è la firma classica di un Nmap -sS per capire quali siano i servizi attivi.

Al pacchetto numero 1, vediamo un “Host Announcement”; la macchina vittima come si legge chiaramente dalla info, è una Metasploitable. Probabilmente stava cercando una host discovery e qualcuno si è intromesso.

- Nome Host: METASPLOITABLE
- Commento Server: metasploitable server (Samba 3.0.20-Debian)

La macchina vittima si annuncia in rete rivelando il proprio OS e la versione di Samba. **Metasploitable** è notoriamente vulnerabile. La versione di Samba 3.0.20 è notoriamente affetta da una vulnerabilità critica (CVE-2007-2447).

2. Le modalità di attacco

In questa fase, l'attacco non sembra essere ancora nella fase di *exploitation* attiva (o compromissione completata), ma nella fase di **Reconnaissance (Ricognizione)** ed **Enumeration**.

In questo caso la enumeration va a buon fine, scoprendo i nervi della macchina, trovando la vulnerabilità di Samba.

Ipotesi 1:

Come già abbiamo detto, il pacchetto numero 1 ha esposto Metasploitable, da qui possono essere condotti una serie di attacchi valutati su vulnerabilità storiche.

Questa specifica versione di Samba, se configurata con l'opzione username map script attiva (default in molte installazioni legacy), permette l'esecuzione arbitraria di comandi.

L'attaccante può inviare una richiesta di login SMB manipolata contenente metacaratteri della shell (es. `nohup /bin/sh`) nel campo *username*.

Risultato: Ottenimento immediato di una **Reverse Shell** o **Bind Shell** con privilegi di root, senza necessità di conoscere una password valida.

Ipotesi 2:

4 23.764777323	192.168.200.150	192.168.200.100	TCP	74 80 - 53860 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294951165 TSecr=818522427 WS=64
5 23.764777427	192.168.200.150	192.168.200.100	TCP	60 443 - 33870 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
6 23.764815289	192.168.200.100	192.168.200.150	TCP	60 53860 - 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=818522428 TSecr=4294951165
6 23.764815291	192.168.200.150	192.168.200.150	TCP	60 83502 - 80 [ACK] Seq=0 Ack=1 Win=0 Len=0
8 28.761629461	PCSSystemtec_fd:87:...	PCSSystemtec_39:7d:...	ARP	60 who has 192.168.200.100? Tell 192.168.200.150
9 28.761644619	PCSSystemtec_39:7d:...	PCSSystemtec_fd:87:...	ARP	42 192.168.200.100 is at 08:00:27:39:7d:fe
10 28.774852257	PCSSystemtec_39:7d:...	PCSSystemtec_fd:87:...	ARP	42 who has 192.168.200.100? Tell 192.168.200.100
11 28.775238099	PCSSystemtec_fd:87:...	PCSSystemtec_39:7d:...	ARP	60 192.168.200.150 is at 08:00:27:fd:87:1e
12 36.774143445	192.168.200.100	192.168.200.150	TCP	74 41384 - 23 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=818535437 TSecr=0 WS=128
13 36.774218116	192.168.200.100	192.168.200.150	TCP	74 56120 - 111 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=818535437 TSecr=0 WS=128
14 36.774257841	192.168.200.100	192.168.200.150	TCP	74 33878 - 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=818535437 TSecr=0 WS=128
15 36.774366305	192.168.200.100	192.168.200.150	TCP	74 58636 - 554 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=818535438 TSecr=0 WS=128
16 36.774485627	192.168.200.100	192.168.200.150	TCP	74 52358 - 135 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=818535438 TSecr=0 WS=128
17 36.774535534	192.168.200.100	192.168.200.150	TCP	74 46138 - 993 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=818535438 TSecr=0 WS=128
18 36.774614776	192.168.200.100	192.168.200.150	TCP	74 41182 - 21 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=818535438 TSecr=0 WS=128
19 36.774855595	192.168.200.150	192.168.200.100	TCP	74 23 - 41384 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=818535437 WS=64
20 36.774855595	192.168.200.150	192.168.200.100	TCP	74 111 - 56120 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=818535437 WS=64
21 36.774855595	192.168.200.150	192.168.200.100	TCP	60 443 - 33870 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
22 36.774855737	192.168.200.150	192.168.200.100	TCP	60 854 - 58636 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
23 36.774855776	192.168.200.150	192.168.200.100	TCP	60 135 - 52358 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
24 36.774855776	192.168.200.150	192.168.200.100	TCP	60 135 - 52358 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0

Encapsulation type: Ethernet (1)
Arrival Time: Aug 9, 2022 09:59:36.668432267 EDT
UTC Arrival Time: Aug 9, 2022 09:59:36.668432267 UTC
Epoch Arrival Time: 1668099176.668432267
[Time shift for this packet: 0.000000000 seconds]
[Time delta from previous captured frame: 79.242 microseconds]
[Time delta from previous displayed frame: 79.242 microseconds]
[Time since reference or first frame: 36.774614776 seconds]
Frame Number: 18
Frame Length: 74 bytes (592 bits)
Capture Length: 74 bytes (592 bits)
[Frame is marked: False]
[Frame is ignored: False]
[Protocols in frame: eth:ethertype:ip:tcp]
Character encoding: ASCII (0)
[Coloring Rule Names: TCP SYN/FIN]
[Coloring Rule String: tcp.flags.fin == 1]
Ethernet II, Src: PCSSystemtec_39:7d:fe (08:00:27:39:7d:fe), Dst: PCSSystemtec_fd:87:1e (08:00:27:fd:87:1e)
Internet Protocol Version 4, Src: 192.168.200.100, Dst: 192.168.200.150
Transmission Control Protocol, Src Port: 41182, Dst Port: 21, Seq: 0, Len: 0
Source Port: 41182

Pacchetto n. 18. La scansione rileva attività sulla **Porta 21 (FTP)**.

Il vettore d'attacco possibile è su **VSFTPD v2.3.4 Backdoor (CVE-2011-2523)**.

La *Metasploitable* esegue spesso la versione 2.3.4 del demone *vsftpd*.

Questa versione specifica contiene una backdoor malevola inserita nel codice sorgente originale dagli sviluppatori (compromessi).

In questo caso, l'attaccante tenta il login con un username che termina con una "faccina sorridente" :) (es. user:)). (è geniale, comunque)

Il servizio apre una shell di root in ascolto sulla porta 6200.

Ipotesi 3:

11 28.775238099	PCSSystemtec_fd:87:...	PCSSystemtec_39:7d:...	ARP	60 192.168.200.150 is at 08:00:27:fd:87:1e
12 36.774143445	192.168.200.100	192.168.200.150	TCP	74 41384 - 23 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=818535437 TSecr=0 WS=128
13 36.774218116	192.168.200.100	192.168.200.150	TCP	74 56120 - 111 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=818535437 TSecr=0 WS=128
14 36.774257841	192.168.200.100	192.168.200.150	TCP	74 33878 - 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=818535437 TSecr=0 WS=128
15 36.774366305	192.168.200.100	192.168.200.150	TCP	74 58636 - 554 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=818535438 TSecr=0 WS=128
16 36.774485627	192.168.200.100	192.168.200.150	TCP	74 52358 - 135 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=818535438 TSecr=0 WS=128
17 36.774535534	192.168.200.100	192.168.200.150	TCP	74 46138 - 993 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=818535438 TSecr=0 WS=128

Pacchetto n. 12. La scansione punta alla **Porta 23 (Telnet)**.

Essendo in chiaro, si può tentare un **Brute Force** o **Sniffing (MITM)**.

Metasploitable è un ambiente di test, quindi, è probabile che ci sia uso di credenziali di default (es. msfadmin:msfadmin, user:user).

L'attaccante potrebbe tentare un attacco a dizionario (es. con *Hydra* o *Medusa*) verso la porta 23.

3. Strategie di Mitigazione

Per ridurre gli impatti dell'attacco in corso e prevenire scenari analoghi futuri, viene suggerita la seguente roadmap operativa, divisa per priorità:

1. Azioni di Contenimento Immediato (*Stop the Bleeding*)

- **Isolamento dell'Host:** Disconnettere immediatamente l'host 192.168.200.150 dalla rete. Essendo una macchina *Metasploitable* (vulnerabile by-design), la sua presenza in una rete attiva rappresenta un rischio inaccettabile.
- **Blocco Traffico Attaccante:** Implementare una regola di *deny* sul firewall o una ACL (Access Control List) sullo switch per bloccare tutto il traffico proveniente dall'IP 192.168.200.100.

2. Azioni di Remediation (*Fix the Vulnerability*)

- **Patching Critico:** Il servizio Samba versione 3.0.20 è affetto dalla vulnerabilità **CVE-2007-2447**. È imperativo aggiornare il servizio a una versione recente e stabile.
- **Hardening dei Servizi:** Disabilitare i servizi non essenziali rilevati durante la scansione. Se il trasferimento file (FTP porta 21) e l'amministrazione remota (Telnet porta 23) non sono strettamente necessari, vanno spenti. Se necessari, vanno migrati su protocolli sicuri (SFTP e SSH).

3. Prevenzione Futura (*Systemic Improvement*)

- **Segmentazione di Rete:** Non posizionare mai sistemi legacy o di test (come questo target) sulla stessa VLAN dei sistemi di produzione o degli utenti. Utilizzare una DMZ o VLAN isolate.
- **Intrusion Detection System (IDS):** Configurare sistemi come Snort o Suricata per rilevare automaticamente pattern di "SYN Scan" e bloccarli prima che l'attaccante completi la mappatura della rete.